

Ripple Stablecoin Contracts Audit



July 1, 2024

Executive Summary

OpenZeppelin was engaged by Ripple to conduct a comprehensive audit of their fiat-backed stablecoin contracts. This audit reflects Ripple's commitment to ensuring the highest standards of security, transparency, and operational excellence in their financial products. Our goal was to identify potential vulnerabilities, verify adherence to best practices, and provide recommendations for enhancing the overall security and functionality of the contracts. The audit only reviewed the smart contract components intended to be deployed on-chain and did not review any deployment scripts, configurations, mock contracts, or tests.

The codebase includes smart contracts for the Ripple stablecoin as well as a contract implementing multi-signature functionality intended to be used for managing all the privileged roles. The stablecoin contract follows the ERC-20 standard for fungible tokens and implements a permissioning system that allows privileged roles managed by the Ripple team to control sensitive functionality. The multi-signature contract requires a minimum quorum of signature weight to be reached for transactions to be executed and all privileged roles are intended to be assigned to instances of this contract.

Within the stablecoin contract, a privileged role can pause accounts thereby preventing them from interacting with the system. Privileged roles are available for managing the minting and burning of tokens as well. The stablecoin contract will be deployed as a proxy contract which allows for future changes to the contract if additional features need to be added or to address unforeseen vulnerabilities in the codebase.

This audit involved two full-time auditors performing a manual, line-by-line review of the entire codebase as well as the use of automated code analysis for vulnerability detection. In particular, the audit validated that:

- All functionality performs as intended.
- The stablecoin contract conforms with the ERC-20 standard.
- External actors can only interact with the system as intended.
- Accounts that have been paused can not interact with the system.
- Best practices are followed for code style and documentation.
- Multi-signature functionality works as intended.

All inherited code used by the audited contracts comes from the OpenZeppelin contracts library which has been previously audited during an internal audit of the v5.0 release.

Scope

We audited the [xpring-eng/stablecoin-contracts](#) repository at commit [3907f32](#).

In scope were the following files:

```
src
├── main
│   └── contracts
│       ├── AccountPausableUpgradeable.sol
│       ├── MultiSign.sol
│       ├── StablecoinProxy.sol
│       └── StablecoinUpgradeable.sol
```

Conclusion

Ripple's new stablecoin on Ethereum includes ERC-20 functionality, pausing features, and a multi-signature contract. Specific roles like minter, burner, upgrader, and pauser are assigned to trusted accounts for managing the stablecoin.

During this audit, we reviewed Ripple's stablecoin contracts, as well as their multi-signature contract. Overall, we found the codebase to be secure, with only low-severity issues identified. The Ripple team was very responsive and provided us with explanations of their design choices.